CERTIFICATION REVISION / FOUNDATIONS TO PRACTICE

INFORMATION SECURITY AND ETHICAL HACKING: STUDY NOTES



A hardware security key supports strong authentication. Security also depends on people, processes and permission.

Understand what must be protected, how attacks develop, and how authorized testing improves defenses.

Build the foundations

Review the **CIA triad**, risk, threat actors, malware and social engineering. Distinguish an asset from a threat, a vulnerability and an exploit before studying attack phases.

Connect practice to purpose

Link attacker behavior to layered controls, incident response and penetration testing. Finish with reporting, laws and standards that govern security work.

> Use each page for active recall: cover the definitions, explain the distinctions aloud, then apply them to a short scenario. These notes support certification study; they do not replace the current exam objectives or legal advice.

Practice only in isolated labs or on systems covered by explicit written authorization. Good intentions do not grant permission.

Information security protects confidentiality, integrity and availability

Information security protects information in storage, transit and use. The **CIA triad** groups three objectives: prevent disclosure or unauthorized change, and preserve access.

Confidentiality

Only authorized parties access information. Permissions and encryption reduce disclosure, such as an outsider reading customer records.

Integrity

Information stays accurate and changes are authorized. Hashes, signatures and change controls help reveal unauthorized modification.

Availability

Authorized users can access services when needed. Redundancy, backups and recovery planning reduce outages and disruption.

Extended goals

Authenticity establishes that an identity or message is genuine. **Non-repudiation** provides evidence that makes denying an action difficult, often through digital signatures and trustworthy records.

Term	Meaning
Asset	Something valuable that needs protection.
Threat	A potential cause of harm.
Vulnerability	A weakness a threat could exploit.
Risk / exploit	Risk concerns possible loss; an exploit uses a weakness.

Security is a balance of functionality, usability and protection

A useful system must do its job, remain practical to use and resist abuse. Strong design considers all three goals rather than maximizing one in isolation.



The triangle represents design tensions, not a fixed mathematical relationship.

Reason about risk

$$\text{Risk} \approx \text{Threat} \times \text{Vulnerability} \times \text{Impact}$$

This study shorthand connects the chance of harmful events, exploitable weaknesses and consequences. Real assessments may use likelihood and impact ratings rather than literal multiplication.

- **Defense in depth** combines independent safeguards so one failure does not expose everything.
- **Least privilege** gives each identity only the access needed, for only as long as needed.

> Example: strong authentication can add friction. Well-designed recovery and accessible authentication reduce that friction without removing the safeguard.

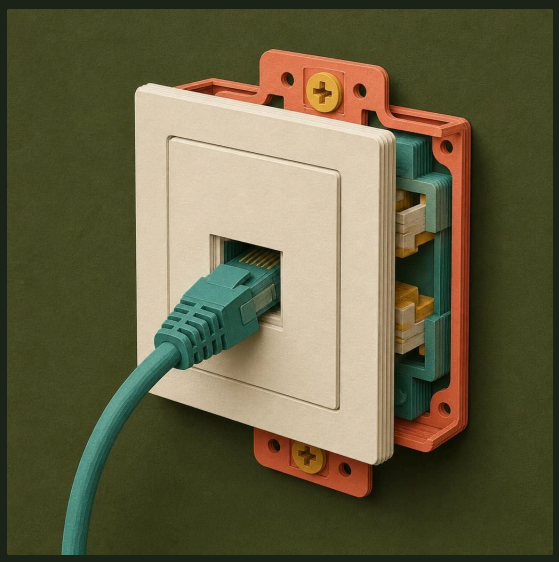
Attackers are driven by motives, goals and objectives

Motive explains why an actor attacks. A **goal** describes the desired outcome; an **objective** makes that outcome concrete, such as stealing a particular dataset.

Read the combination

Motive plus method plus vulnerability equals attack. Treat this as a memory aid: a motivated actor chooses a method that can exploit an available weakness.

- **Money** drives theft, fraud and extortion.
- **Disruption** aims to interrupt operations.
- **Espionage** seeks valuable intelligence.
- **Activism** promotes a political or social cause.



Access opportunities matter alongside intent.

Actor	Typical distinction
Script kiddies	Use existing tools with limited understanding.
Insiders	Have legitimate access or organizational knowledge.
Criminal groups	Often organize attacks for financial gain.
State-sponsored groups	May pursue strategic espionage or disruption.

> Actor labels are not proof of attribution. Capability, opportunity and observed behavior matter more than stereotypes.

Threats fall into network, host and application categories

Classify a threat by the surface it targets. The categories overlap: one incident can cross a network, compromise a host and abuse an application.

COMMUNICATIONS AND CONNECTIVITY

Network threats

Eavesdropping exposes traffic. **Spoofing** falsifies an identity or address. **Denial of service** exhausts resources. A **man-in-the-middle** intercepts or alters communication between parties.

Useful defenses include encrypted transport, segmentation, authenticated protocols and traffic filtering.

ENDPOINTS AND OPERATING SYSTEMS

Host threats

Malware abuses the device. **Password attacks** target credentials. **Privilege escalation** increases an actor's rights beyond the initial access level.

Patch systems, restrict administrative rights and monitor endpoint activity.

SOFTWARE AND BUSINESS LOGIC

Application threats

Injection makes untrusted input act as instructions. **Broken authentication** undermines identity checks or sessions. **Misconfiguration** exposes unsafe settings or unnecessary services.

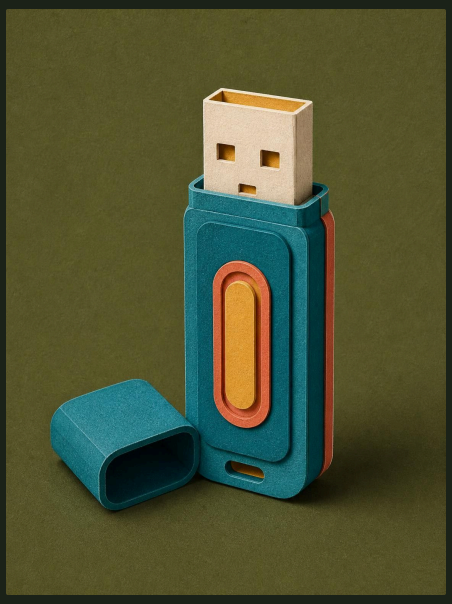
Use secure defaults, parameterized queries, robust session controls and security testing.

> Exam cue: identify what is attacked before choosing a control. A firewall alone cannot repair insecure application logic.

Malware is the most common attack vector

Malware is software intended to harm, spy on or control systems. It is widespread, but "most common" depends on the dataset; malware is often the payload delivered through another vector.

Family	Spread and target
Virus	Attaches to a host file; spreads when infected content runs.
Worm	Self-propagates between systems, often exploiting network weaknesses.
Trojan	Poses as legitimate software to induce execution.
Ransomware	Encrypts or steals data to support extortion.
Spyware	Collects information such as activity or credentials.
Rootkit	Conceals malicious presence or privileged access.



Removable media can carry malicious files.

Beyond traditional files

Fileless malware can abuse memory, scripts and trusted system tools, reducing reliance on ordinary executable files. Fileless does not mean evidence-free.

An **advanced persistent threat** is a sustained, capable threat actor or campaign, not a malware family. Such campaigns may combine malware, stolen credentials and legitimate tools.

> Remember behavior, not appearance: a trojan deceives; a worm propagates; a rootkit hides. One malicious program may fit several categories.

Social engineering exploits people rather than systems

Social engineering manipulates trust, urgency, fear or curiosity to induce unsafe actions. Attackers may request credentials, money, sensitive information or physical access without exploiting software.

Technique	Recognize the distinction
Phishing	Deceptive messages sent to lure recipients into unsafe actions.
Spear phishing	Targeted phishing tailored to a person or organization.
Vishing / smishing	Voice calls / SMS messages used as the delivery channel.
Pretexting	A fabricated story creates a reason to request information.
Baiting	An enticing offer or object encourages risky behavior.
Tailgating	An unauthorized person follows someone into a restricted space.
Impersonation	The attacker pretends to be a trusted person or role.

Warning signs

- Unexpected urgency or secrecy.
- Requests to bypass normal approvals.
- Mismatched domains or unusual payment details.
- Unsolicited MFA prompts or attachment requests.

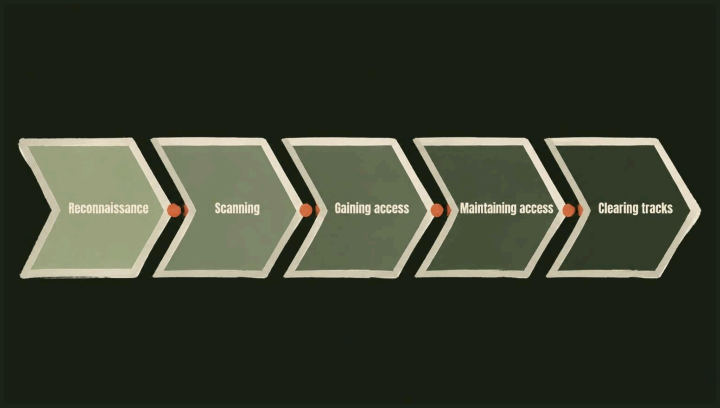
Human-layer defenses

- Verify through a known, separate channel.
- Use established approval workflows.
- Report suspicious contact promptly.
- Challenge unfamiliar visitors safely.

> Memory aid: pause, verify, report. A familiar name or polished message does not establish authenticity.

Hacking follows five phases

This teaching model organizes common attacker activities. Real intrusions may repeat, overlap or skip phases; authorized testers perform only explicitly permitted activities.



A study model of attacker activity, not an instruction sequence.

01 Reconnaissance

Gather information about the target. Passive research avoids direct interaction; active research interacts with target systems.

02 Scanning

Identify reachable systems, services and potential weaknesses. Observations still require validation.

03 Gaining access

An attacker exploits a weakness or misuses credentials to enter a system.

04 Maintaining access

An attacker attempts to retain a foothold. Persistence testing requires separate, explicit approval.

05 Clearing tracks

An attacker tries to conceal activity. Ethical testers preserve evidence and remove only approved test artifacts.

> Recall the order: learn, discover, enter, remain, conceal. Do not confuse this model with a mandatory penetration-test methodology.

The Cyber Kill Chain and MITRE ATT&CK describe attacker behavior

The **Cyber Kill Chain** summarizes intrusion progression. **MITRE ATT&CK** catalogs observed adversary behavior in more detail. Neither guarantees a fixed sequence for every incident.

Cyber Kill Chain

1. **Reconnaissance** gathers target information.
2. **Weaponization** prepares an attack capability.
3. **Delivery** brings it to the target.
4. **Exploitation** triggers a weakness.
5. **Installation** establishes malicious capability.
6. **Command and control** enables attacker communication.
7. **Actions on objectives** achieve the attacker's goal.

ATT&CK vocabulary

- A **tactic** expresses why an activity is performed, such as credential access.
- A **technique** describes how that objective is achieved.
- A **procedure** is the specific implementation observed in a campaign.

Indicators of compromise include suspicious hashes, domains or artifacts. Defenders correlate them with logs and behavior to investigate, detect and hunt for related activity.

> Distinguish evidence from explanation: an indicator suggests what to look for; an ATT&CK mapping describes behavior. An indicator alone rarely proves compromise.

Hacker classes are defined by intent and permission

Hacker labels describe broad patterns of intent and conduct. They are study vocabulary, not legal categories, and they do not establish an individual's permission to test.

Class	Defining idea
White hat	Tests with authorization to identify and help correct weaknesses.
Black hat	Acts maliciously or pursues unauthorized harmful access.
Gray hat	May discover or disclose weaknesses without permission, despite claiming helpful intent.
Suicide hacker	A legacy study label for an actor unconcerned about exposure or consequences.
Hacktivist	Acts in support of a political or social cause.
State-sponsored hacker	Operates with state backing or in support of national objectives.

AUTHORIZATION IS THE BOUNDARY. INTENT IS NOT PERMISSION.

Apply the distinction

Finding an exposed service does not authorize access. A public website is not an invitation to test it. A bug-bounty program grants permission only within its published scope and conditions.

> Exam cue: a person who "only wanted to help" may still have acted without authorization. Check the owner's consent, the named targets and the permitted activities before classifying a test as ethical.

Ethical hacking tests defenses with permission

Ethical hacking uses authorized adversarial testing to find weaknesses, validate controls and explain business impact before an attacker causes harm.

Permission before activity

- Obtain **written authorization** from an appropriate owner.
- Define **scope**: systems, identities, locations and exclusions.
- Agree **rules of engagement**: timing, methods, contacts and stop conditions.
- Specify evidence handling, confidentiality and cleanup.



An identity badge is not blanket testing permission.

Skills and limits

Testers need networking, operating-system and application knowledge, analytical judgment and clear communication. They must recognize when a test could disrupt production, expose sensitive records or cross an agreed boundary.

A test samples a particular environment at a particular time. It cannot prove the absence of vulnerabilities or guarantee future security. Findings need remediation, ownership and verification.

> Stop and escalate unexpected sensitive access, instability or out-of-scope exposure. Record enough evidence to demonstrate impact without collecting unnecessary data.

Information security controls work in layers

Defense in depth combines safeguards across people, processes and technology. Layers should reduce shared failure modes, not merely repeat the same weak control.

Administrative layer

Policies, training, supplier requirements and separation of duties establish expectations and accountability.

Technical layer

Access controls, encryption, segmentation and monitoring enforce or observe system behavior.

Physical layer

Locks, barriers, visitor controls and environmental protection safeguard facilities and equipment.

Control category describes its form. Control function describes what it does.

Function	Purpose	Example
Preventive	Block or reduce an event.	MFA or a locked door
Detective	Discover an event.	An alert or audit
Corrective	Restore or improve conditions.	Recovery or patching
Deterrent	Discourage unwanted behavior.	Visible enforcement notices

> One control can serve several functions. A camera may deter activity and provide detective evidence; classify it by the scenario's stated purpose.

Choose layers around business risks and critical assets. Review whether a failure in one identity, supplier or platform could bypass several safeguards at once.

Technical controls enforce policy in systems

Technical controls translate policy into system behavior. Their effectiveness depends on configuration, maintenance and the ability to respond when something goes wrong.

Control	Purpose and limitation
Firewall	Allows or blocks traffic by rules. Permitted traffic may still contain attacks.
IDS / IPS	An IDS detects suspicious activity; an IPS can block it inline. Both need tuning.
Encryption	Protects confidentiality in storage or transit. Key management remains essential.
Access control	Restricts actions according to identity, role, attributes or other policy conditions.
MFA	Combines different factor types. Two passwords are still one factor type.
Endpoint protection	Helps prevent, detect and investigate malicious activity on devices.

Keep systems hardened

Patch management inventories, prioritizes, tests and deploys updates. Remove unused services, apply secure baselines and verify changes rather than assuming deployment succeeded.

Make activity visible

Logging records events; **monitoring** watches for meaningful changes. A **SIEM** aggregates and correlates security events to support investigation and response.

> Memory aid: prevent, observe, respond. A SIEM is not a substitute for useful telemetry, trained analysts or an incident-response process.

Risk management and incident response keep security running

Risk management is continuous. Identify assets and threats, assess likelihood and impact, choose treatment and monitor whether the remaining risk is acceptable.

Treat risk deliberately

- **Avoid** an activity that creates unacceptable risk.
- **Mitigate** likelihood or impact with controls.
- **Transfer** some consequences through contracts or insurance.
- **Accept** residual risk through an accountable decision.

Incident-response lifecycle

Activity	Operational purpose
Prepare	Establish roles, playbooks, tools and communications.
Detect	Validate alerts, investigate and determine scope.
Contain	Limit spread and reduce immediate damage.
Eradicate	Remove the cause and attacker footholds.
Recover	Restore trusted services and monitor closely.
Review	Capture lessons and improve controls.

Activities can overlap or repeat as new evidence changes the incident picture.

Business continuity sustains critical business activities during disruption. **Disaster recovery** restores supporting systems and data. Recovery time objectives concern restoration time; recovery point objectives concern tolerable data loss measured in time.

> Containment limits harm; eradication removes the cause. Preserve evidence and coordinate disruptive actions with the incident lead.

Penetration testing is a structured, authorized attack simulation

A **penetration test** validates whether weaknesses can be exploited within agreed limits and explains the resulting impact. It is controlled testing, not unrestricted access.

Vulnerability assessment

Identifies and prioritizes potential weaknesses. It usually emphasizes coverage and may rely heavily on scanning and validation.

Penetration test

Uses permitted exploitation to demonstrate attack paths and consequences. It may connect several weaknesses into a larger finding.

Discovery identifies possible exposure; controlled exploitation demonstrates achievable impact.

How much does the tester know?

Black box · Minimal prior knowledge

Models an unfamiliar starting point; discovery consumes more testing time.

Gray box · Partial knowledge or access

Supplies selected context or credentials to focus the assessment.

White box · Extensive knowledge

Provides architecture, source code or privileged context for deeper coverage.

External tests examine exposed services; **internal** tests begin inside an environment. Web, wireless and social engineering assessments target distinct surfaces and require explicit scope.

> Knowledge level and test location are separate dimensions. A white-box engagement can still assess an externally exposed application.

A penetration test moves through three stages

Each stage has a different purpose and deliverable. Written authorization and the rules of engagement govern the entire lifecycle, including intelligence gathering and cleanup.

01

Pre-attack

Define objectives, scope, exclusions and success criteria. Agree contracts, authorization, test windows, emergency contacts, data handling and stop conditions. Gather permitted intelligence and understand the environment.

Output: an approved plan that states what may be tested, how and when.

02

Attack

Validate weaknesses through controlled exploitation. Privilege escalation and pivoting are allowed only when approved. Minimize disruption, record evidence and pause if a test threatens safety or exceeds scope.

Output: reproducible findings with evidence of access, affected assets and business impact.

03

Post-attack

Remove approved test artifacts, restore agreed settings and account for test credentials or data. Report findings, recommend remediation and arrange retesting with the system owner.

Output: a report, cleanup record and prioritized remediation guidance.

> Memory aid: agree, validate, improve. Cleanup removes test artifacts; it does not mean deleting audit logs or concealing the engagement.

Pen test reports turn findings into action

A useful report connects technical evidence to business consequences and gives an owner a practical route to resolution. Separate confirmed findings from assumptions and untested possibilities.

Executive summary

Explain objectives, scope, major risks and overall themes in business language. State limitations, coverage gaps and the engagement's time-bound nature.

Technical findings

Record affected assets, prerequisites, observed behavior and reproducible evidence. Explain the attack path and impact while redacting secrets and unnecessary personal data.

Severity and priority

Use a consistent severity method, such as **CVSS**, alongside exposure, exploitability, business criticality and existing controls. A technical score alone does not determine remediation order.

Remediation and retesting

Recommend specific corrective actions, an accountable owner and an agreed target date. Retest the fix and check for related weaknesses or regressions.

FINDING → IMPACT → ACTION → VERIFICATION

> Retest status should distinguish fixed, partially fixed, unresolved and not retested. A team's statement that a patch was installed is not evidence that the original weakness is resolved.

Laws shape how security is run and tested

Legal obligations depend on jurisdiction, data, sector and activity. Written permission is essential, but an organization cannot authorize conduct beyond its own legal rights.

Law or regime	What to remember
US CFAA	The Computer Fraud and Abuse Act addresses specified computer-related offenses, including certain unauthorized access.
UK Computer Misuse Act	Addresses unauthorized access and other computer misuse offenses. A helpful motive does not replace authorization.
GDPR	Regulates personal-data processing within its scope. Security testing may involve lawful-basis, minimization and breach-handling duties.
HIPAA	US health-information rules apply to covered entities and business associates, including safeguards for electronic protected health information.
SOX	US public-company financial-reporting obligations include internal-control requirements relevant to supporting IT systems.

Before testing across boundaries

- Confirm who owns the systems and can approve the work.
- Check cloud-provider and third-party testing conditions.
- Agree where evidence is stored and who can access it.
- Identify contractual and incident-notification duties.

> Exam cue: computer misuse concerns unauthorized conduct; privacy law concerns personal-data processing. The same engagement may trigger both. These notes are educational, not legal advice.

Standards give organizations a common security baseline

Standards and frameworks organize expectations, evidence and improvement. They support security decisions but do not guarantee that an organization is secure or legally compliant.

Reference	Primary purpose
ISO/IEC 27001	Requirements for an information security management system, or **ISMS**, built around risk and continual improvement.
ISO/IEC 27000 family	Related standards provide vocabulary and guidance. ISO/IEC 27002 offers guidance on information security controls.
PCI DSS	Security requirements for environments that store, process or transmit payment card data, and systems that can affect their security.
NIST Cybersecurity Framework	A risk-based framework for organizing and communicating cybersecurity outcomes.

NIST CSF 2.0 core functions

Govern establishes direction and oversight.

Identify builds understanding of assets and risks.

Protect applies safeguards.

Detect discovers possible incidents.

Respond manages incident effects.

Recover restores affected capabilities.

> Version cue: CSF 2.0 has six functions, including Govern. Older study material may list only five. PCI DSS is a standard, not a statute; contractual obligations can require compliance.

Exam review: key terms and what to remember

Answer from memory before checking the notes. In scenario questions, identify the asset, objective, permission boundary and requested control before choosing an answer.

Recall prompt	Expected answer
CIA triad	Confidentiality protects secrecy; integrity protects authorized accuracy; availability protects access.
Five hacking phases	Reconnaissance, scanning, gaining access, maintaining access, clearing tracks.
Kill Chain	Reconnaissance, weaponization, delivery, exploitation, installation, command and control, actions on objectives.
Control functions	Preventive, detective, corrective and deterrent.
Control categories	Administrative, technical and physical.
Pen test stages	Pre-attack, attack and post-attack.

Match the situation

- Unauthorized access raises **computer misuse** concerns.
- Personal-data processing may trigger **GDPR** or similar law.
- US protected health information points to **HIPAA**; public-company reporting controls point to **SOX**.
- Payment cards point to **PCI DSS**; an ISMS points to **ISO/IEC 27001**.

> Common traps: threat ≠ vulnerability; authentication ≠ authorization; IDS ≠ IPS; vulnerability assessment ≠ penetration test. Good intent never substitutes for written permission.

Final check: explain why containment differs from eradication, why least privilege limits damage, and why a completed test cannot prove that no vulnerabilities remain.